10/11/2026

Cyber Security Internship Program

DIGITAL FRONSICS

NIDA ASHRAF
NEXASECURE TECH

Contents

WEEK 1 – Fundamentals & Lab Setup 3
Day 2: Networking Basics (TCP/IP, DNS, Ports, HTTP/HTTPS) 4
Day 4: Install Kali Linux 10
Day 5: Install Windows Test Machine 17
Day 6: Linux Commands Practice 19
Day 7: Basic Network Scanning 20
WEEK 2 – Ethical Hacking & Vulnerability Assessment 20
Day 8: Ethical Hacking Methodology 20
. Penetration Testing Methodology & Phases 20
Section 1: Title & Document Control 21
Section 2: Executive Summary 21
Section 3: Scope of Work & Rules of Engagement 22
Section 4: Methodology & Tools Applied 22
Section 5: Detailed Technical Findings 22
Section 6: Remediation & Recommendations 22
Day 9: Reconnaissance 22
Day 10: Advanced Scanning 23
Day 11: Web Vulnerability Scanning 24
Day 13: Password Testing 24
Day 14: Vulnerability Report Writing 25
WEEK 3: Web Security & Blue Team Basics 26
Day 15: OWASP Top 10 Overview 26
OWASP? 26
OWASP Top 10 Vulnerabilities Overview 26
A01:2021 – Broken Access Control 26
A02:2021 – Cryptographic Failures 26
A03:2021 – Injection 27
A04:2021 – Insecure Design 27
A05:2021 – Security Misconfiguration 27
A06:2021 – Vulnerable and Outdated Components 27
A07:2021 – Identification and Authentication Failures 27
A08:2021 – Software and Data Integrity Failures 27
A09:2021 – Security Logging and Monitoring Failures 28
A10:2021 – Server-Side Request Forgery (SSRF) 28
Day 16: XSS Testing 28
Day 17: SQLi 29
Day 18: Log Analysis 30
Day 19: Firewall Configuration 31

Day 21: Incident Simulation 31
WEEK 4 – Hardening & Final Project 32
Day 22: System Hardening Basics 32
Day 23: Firewall Hardening 33
Day 24: Password Policy Implementation 33
Day 25: Patch Management 34
Day 26: Security Baseline Implementation 35
Day 27: Full Lab Security Review 35

WEEK 1 – Fundamentals & Lab Setup

Day 1: Cybersecurity Basics (CIA, Threats, Risk)

- ### CIA Traid:

Principle:

Principle	Description	Real-World Example
Confidentiality	Restricting data access to authorized users only.	Encrypting sensitive databases and enforcing Multi-Factor Authentication (MFA).
Integrity	Safeguarding data against unauthorized alteration or destruction.	Hashing files (SHA-256) to verify data has not been modified in transit.
Availability	Ensuring timely, reliable access to data and systems for authorized users.	Deploying Redundant Arrays of Independent Disks (RAID) and DDoS mitigation.

- ### Risk:

- **Asset:** Anything of value to an organization (e.g., customer database, proprietary code).
- **Vulnerability:** A flaw or weakness in a system's design, implementation, or operation (e.g., unpatched software, weak passwords).
- **Threat:** Any potential cause of an unwanted incident that could harm an asset (e.g., ransomware attack, insider action, hardware failure).
- **Risk:** The overall likelihood and impact of a threat exploiting a specific vulnerability.

$$Risk = Threat * Vulerability * Impact$$

- ### Common Threat Types

- **Phishing:** Social engineering attacks designed to trick users into revealing credentials or sensitive info.
- **Malware:** Malicious software (Ransomware, Trojans, and Spyware) built to compromise systems.
- **Man-in-the-Middle (MitM):** Eavesdropping attacks where an attacker secretly intercepts and alters communication between two parties.
- **Denial-of-Service (DoS/DDoS):** Overwhelming a target system with traffic to make it unavailable to legitimate users.

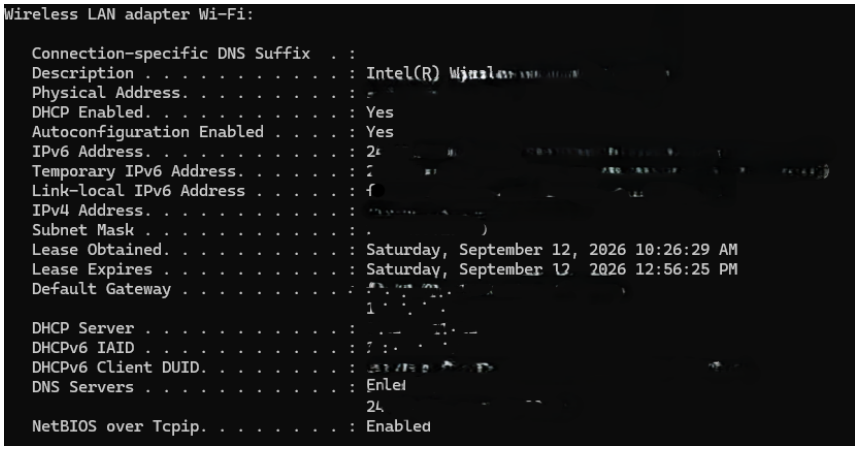
- **Scenario:** A hospital system falls victim to a targeted ransomware attack. During a healthcare ransomware attack, threat actors exfiltrate patient records (**Confidentiality**), encrypt system files so clinical data cannot be trusted or modified (**Integrity**), and lock staff out of life-critical electronic health systems entirely (**Availability**).

Day 2: Networking Basics (TCP/IP, DNS, Ports, HTTP/HTTPS)

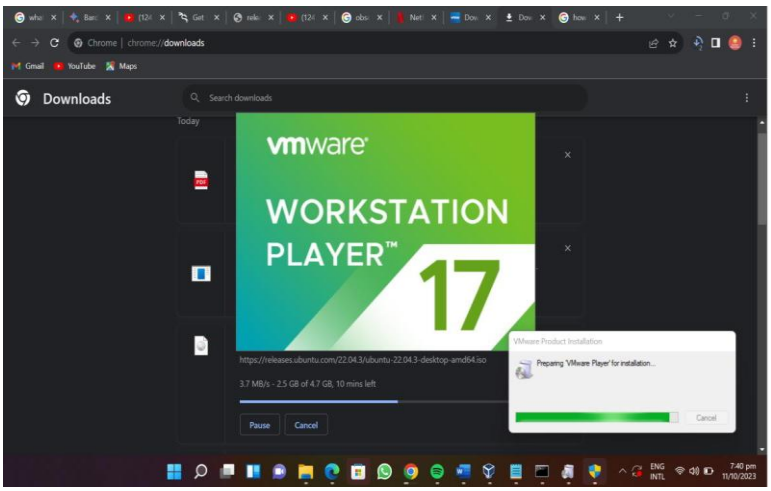
Networking Protocols & Ports

Protocol	Default Port	Transport Layer	Purpose
DNS	53	UDP/TCP	Translates human-readable domain names (e.g., google.com) to IP addresses.
HTTP	80	TCP	Transfers unencrypted web pages across the internet.
HTTPS	443	TCP	Transfers encrypted web pages securely using TLS/SSL.
DHCP	67/68	UDP	Dynamically assigns local IP addresses and network configurations to host devices.

IP configuration:

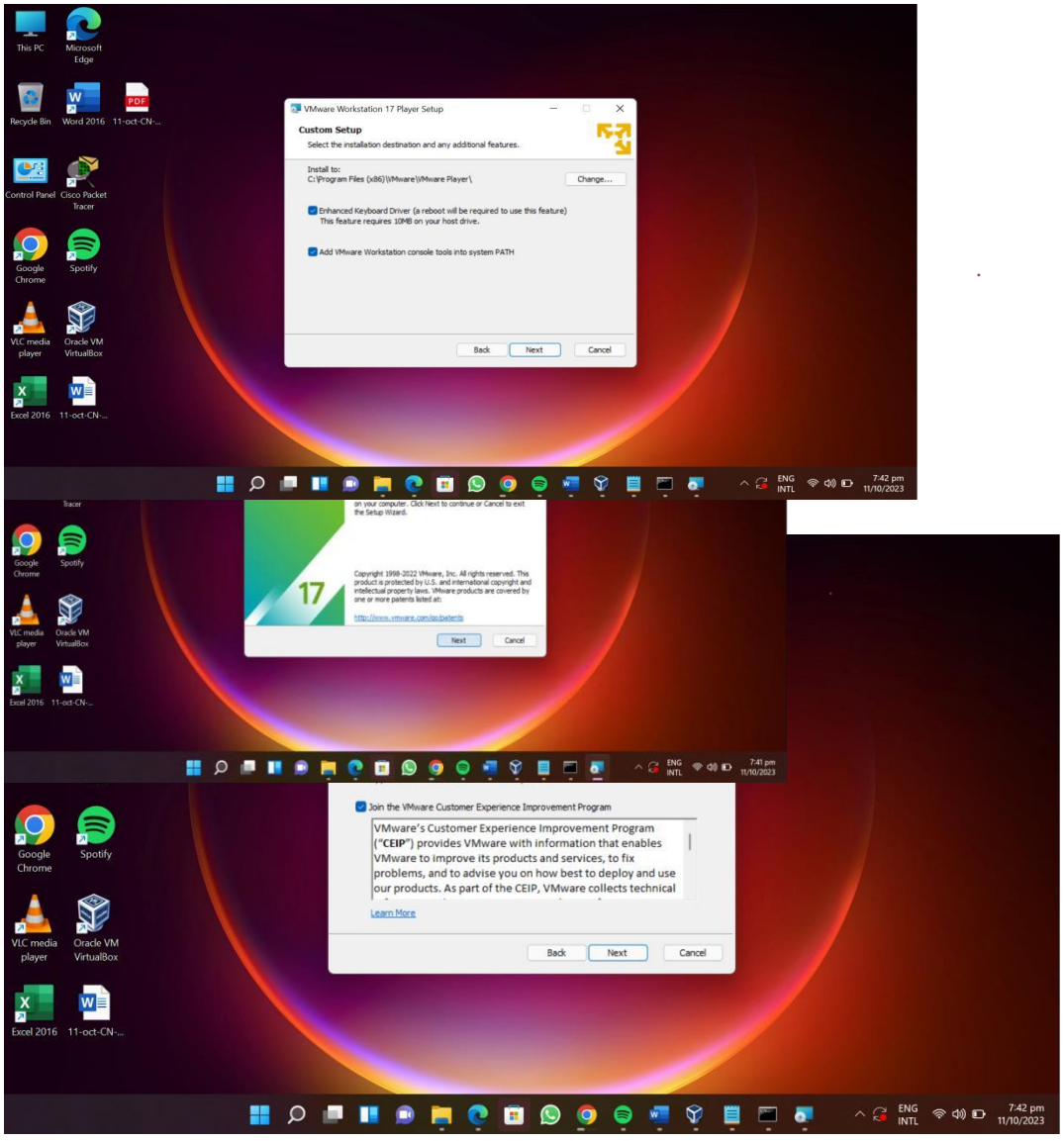


Start Installing VMware WorkStation 17

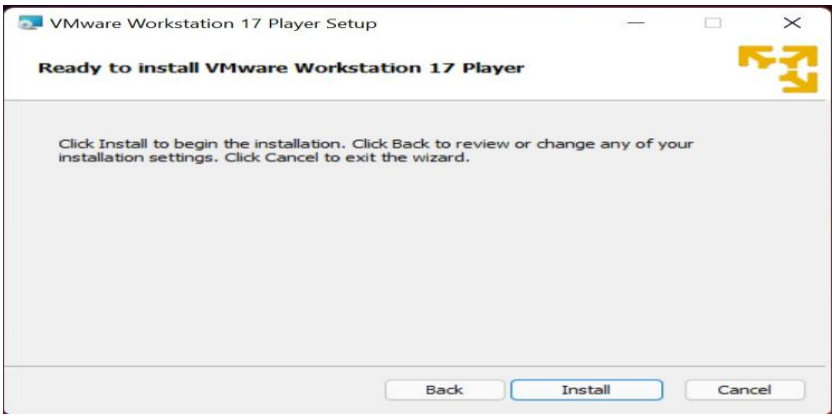


Click next

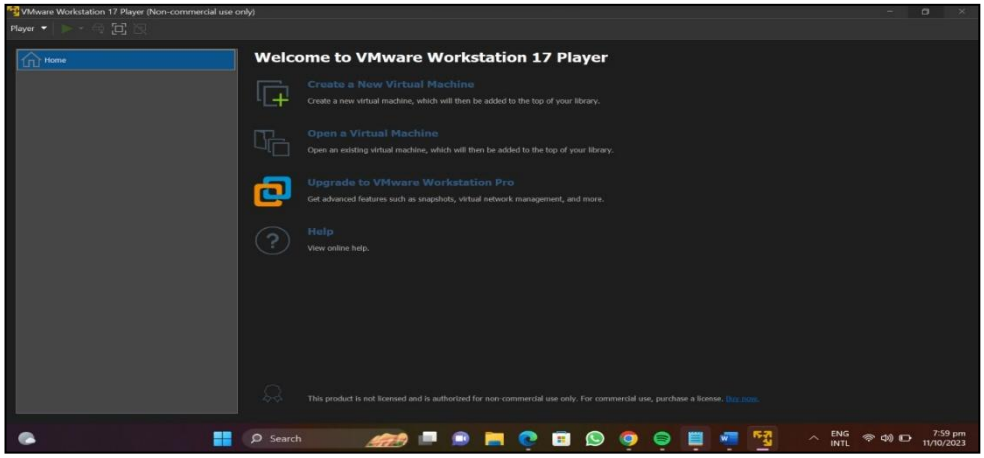
Enable both features by clicking check boxes and click next

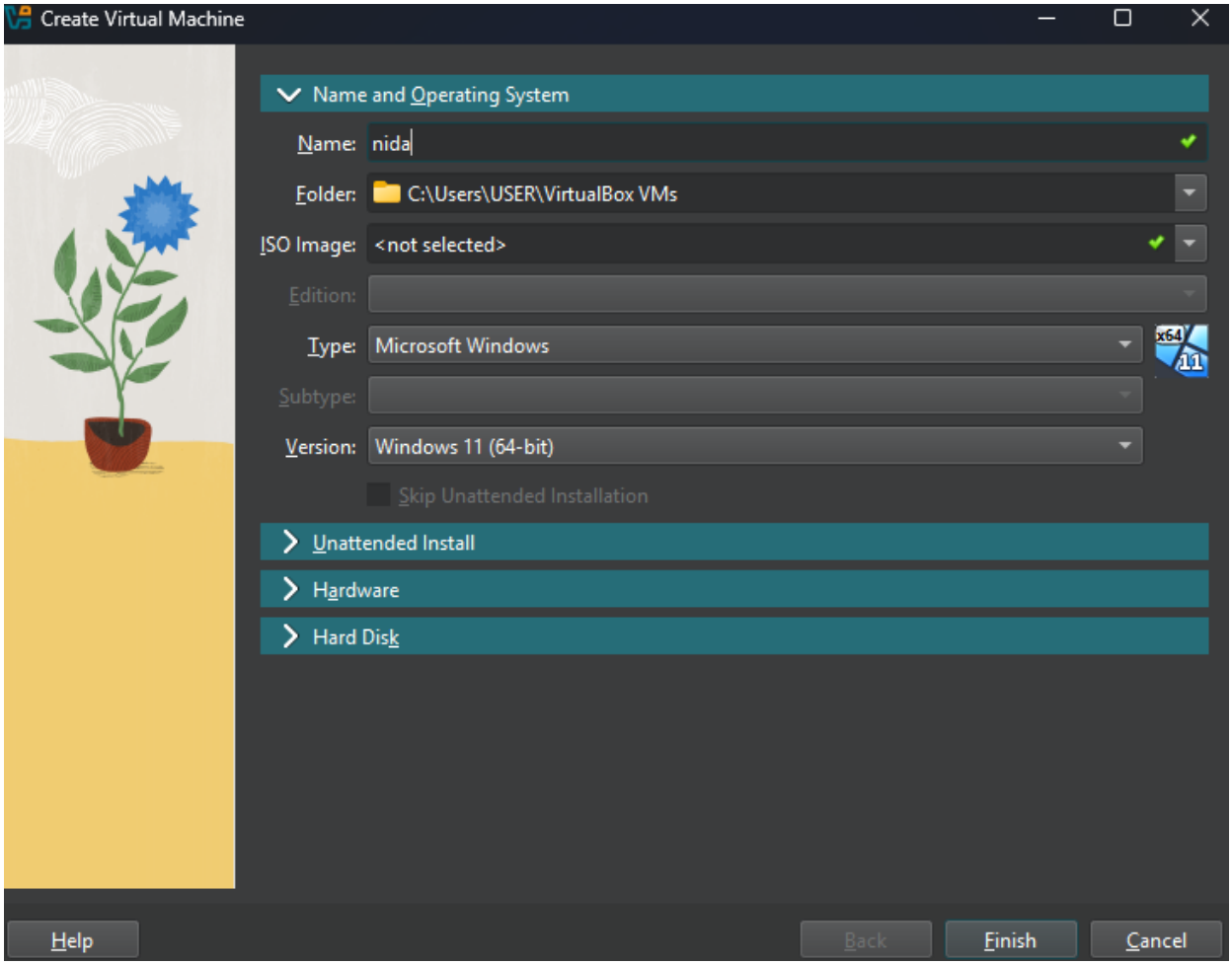


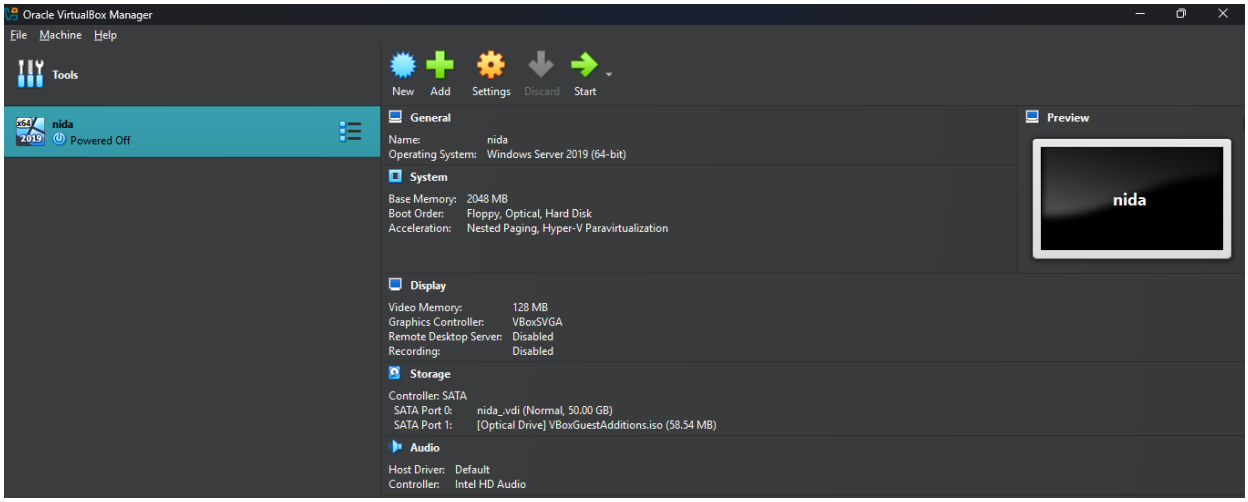
Click on install, wait and then click finish



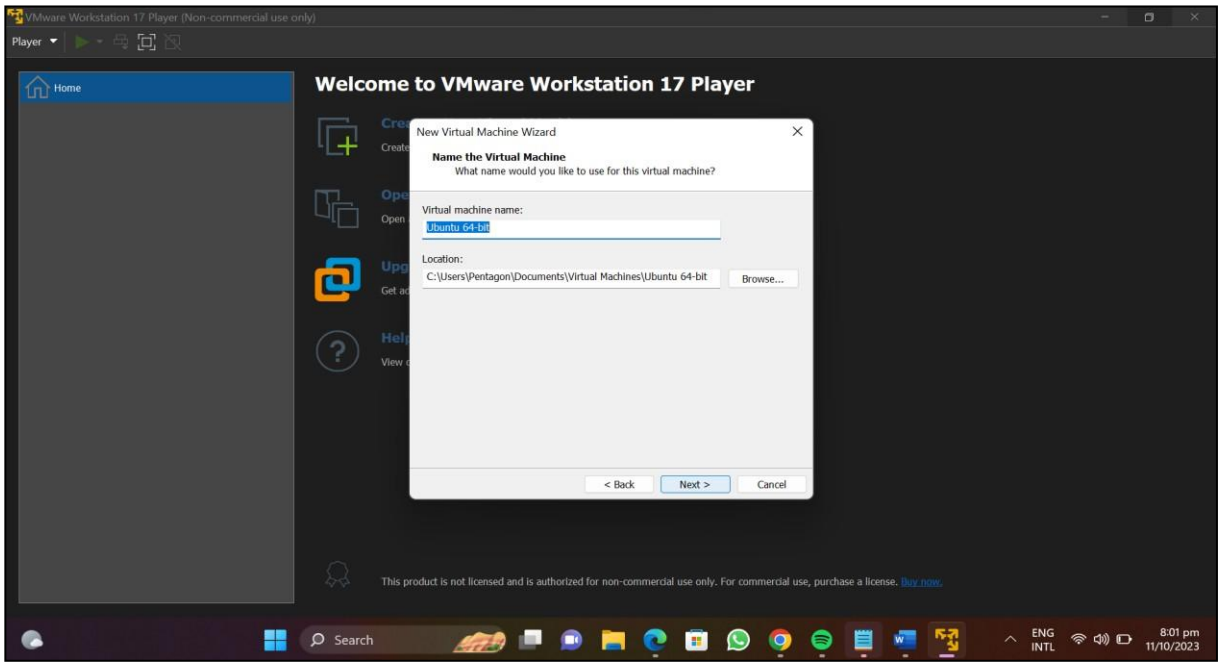




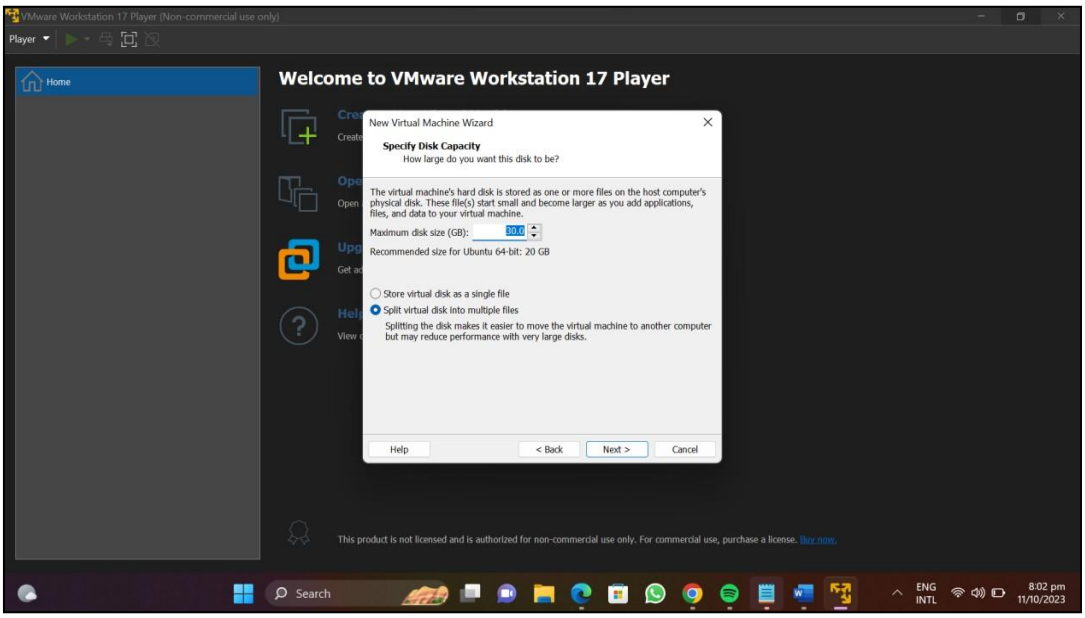

Create Virtual Machine
Name and Operating System
Name: nida
Folder: C:\Users\USER\VirtualBox VMs
ISO Image: <not selected>
Edition:
Type: Microsoft Windows
Subtype:
Version: Windows 11 (64-bit)
Skip Unattended Installation
Unattended Install
Hardware
Hard Disk
Help
Back
Finish
Cancel


Oracle VirtualBox Manager
File Machine Help
Tools
New Add Settings Discard Start
nida
Powered Off
General
Name: nida
Operating System: Windows Server 2019 (64-bit)
System
Base Memory: 2048 MB
Boot Order: Floppy, Optical, Hard Disk
Acceleration: Nested Paging, Hyper-V Paravirtualization
Preview
nida
Display
Video Memory: 128 MB
Graphics Controller: VBoxSVGA
Remote Desktop Server: Disabled
Recording: Disabled
Storage
Controller: SATA
SATA Port 0: nida_.vdi (Normal, 50.00 GB)
SATA Port 1: [Optical Drive] VBoxGuestAdditions.iso (58.54 MB)
Audio
Host Driver: Default
Controller: Intel HD Audio

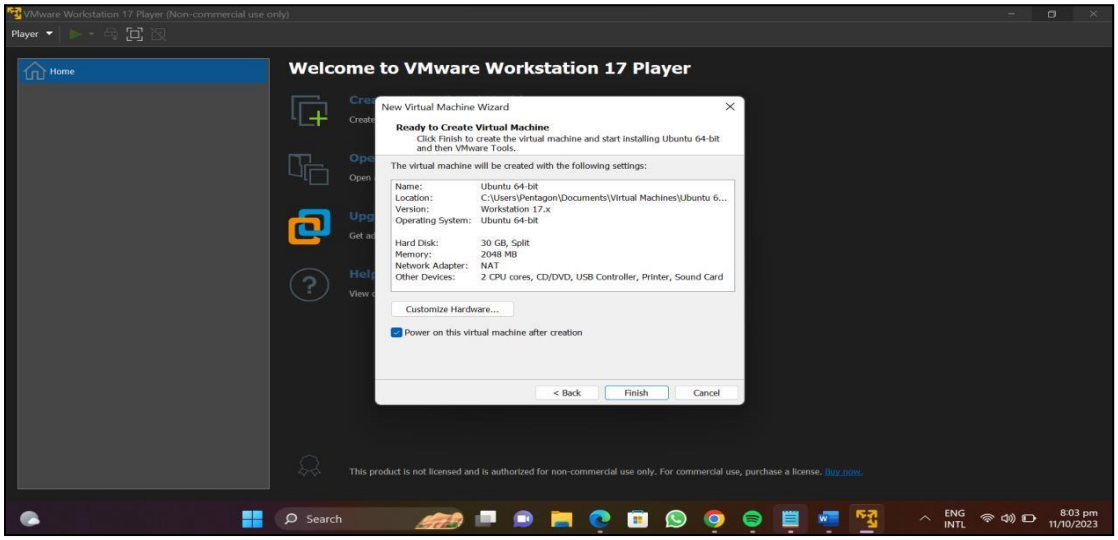
You can change name of Virtual Machine and then click next

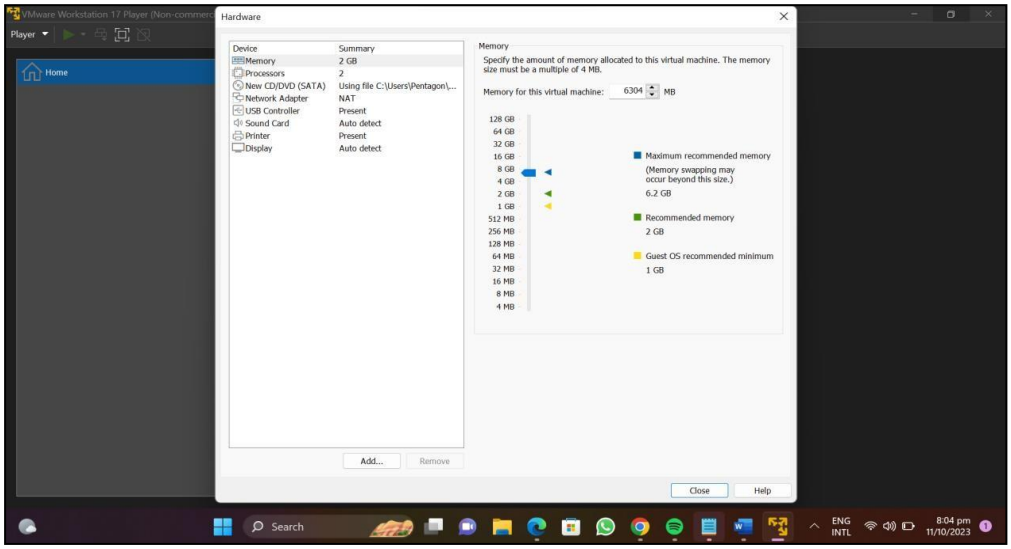


Set the disk size to minimum 20.00 GB or maximum you want according to your PC and check on “Store virtual disk as a single file”



Click on Customize Hardware and do some changes for best experience according to your PC

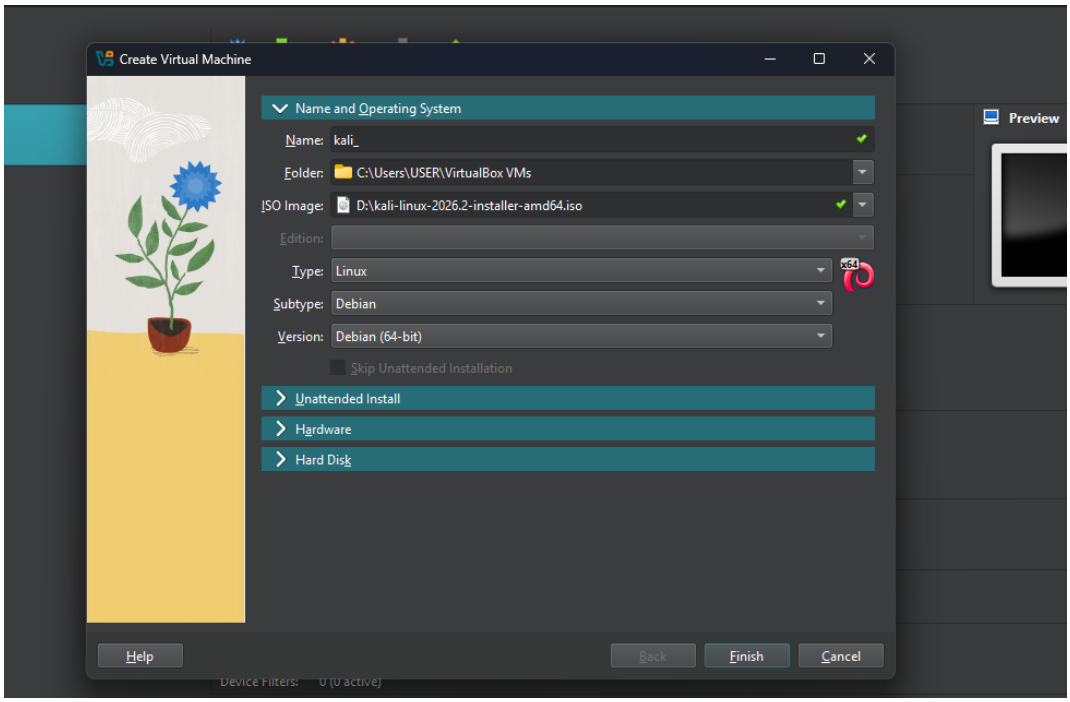


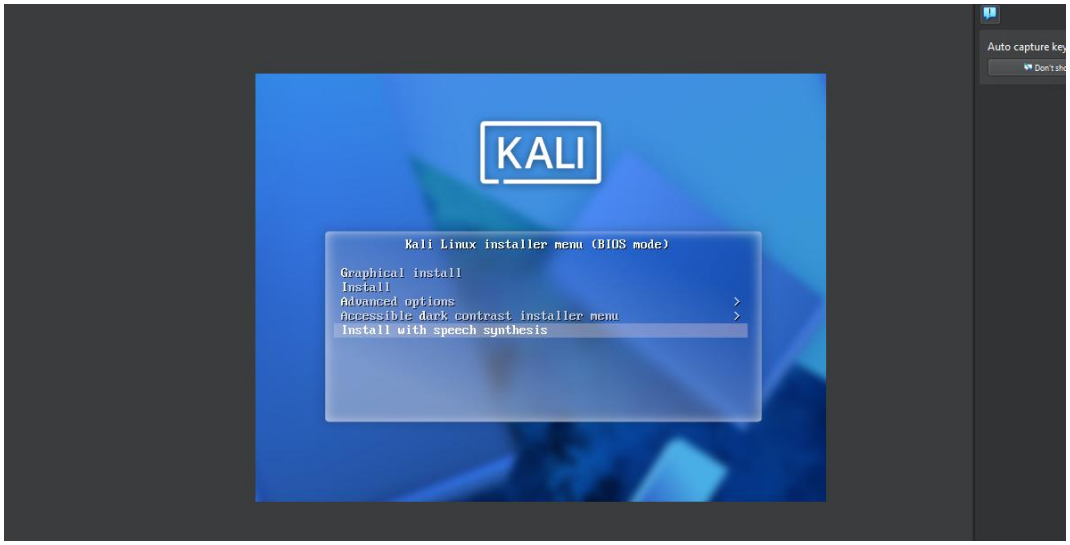


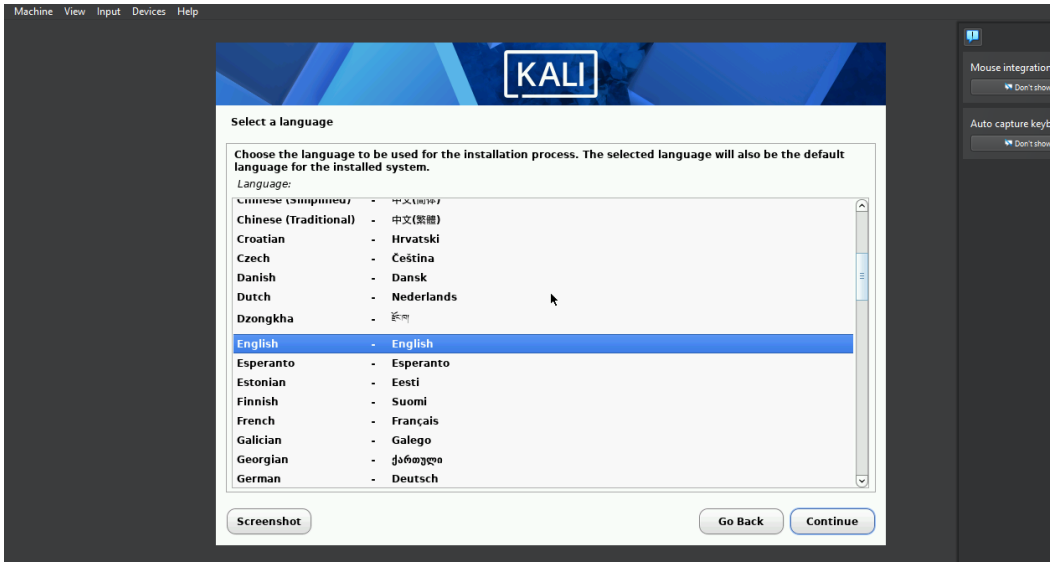
Day 4: Install Kali Linux

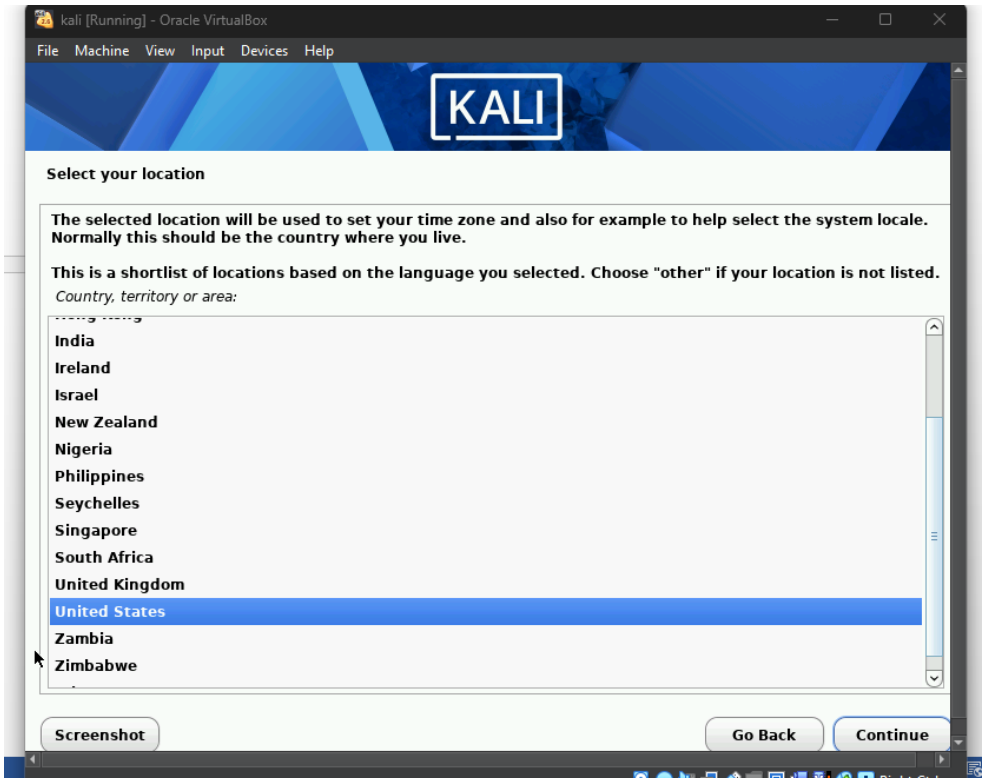
Tools: Kali Linux ISO, VirtualBox / VMware

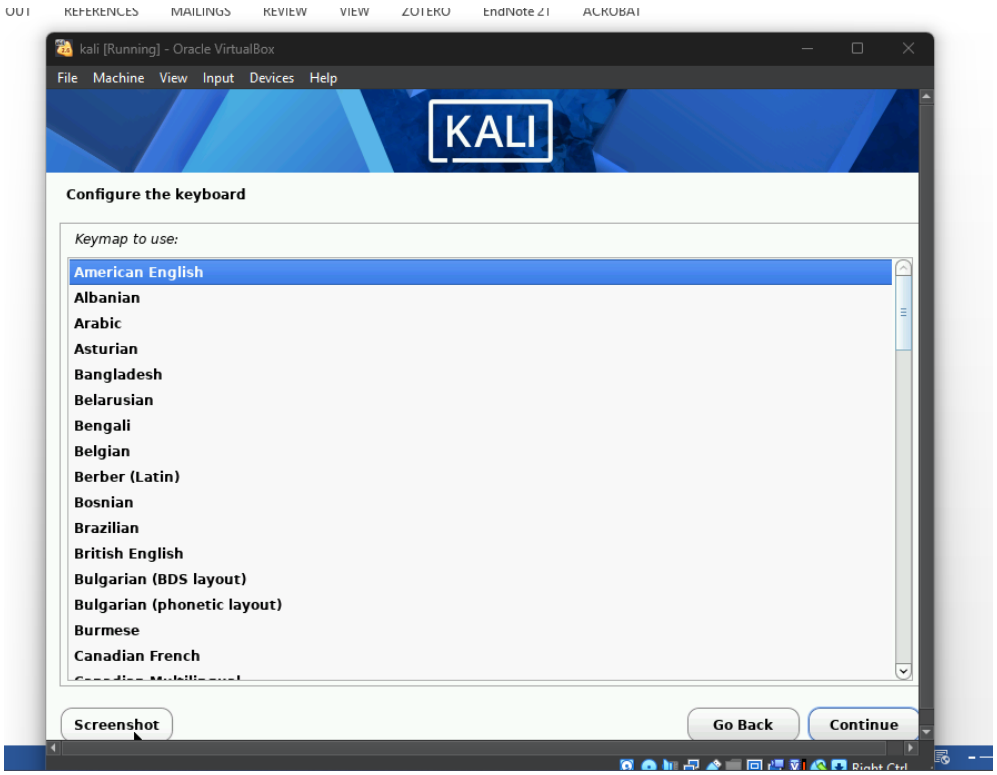
Practical Task: Install Kali Linux inside VM.

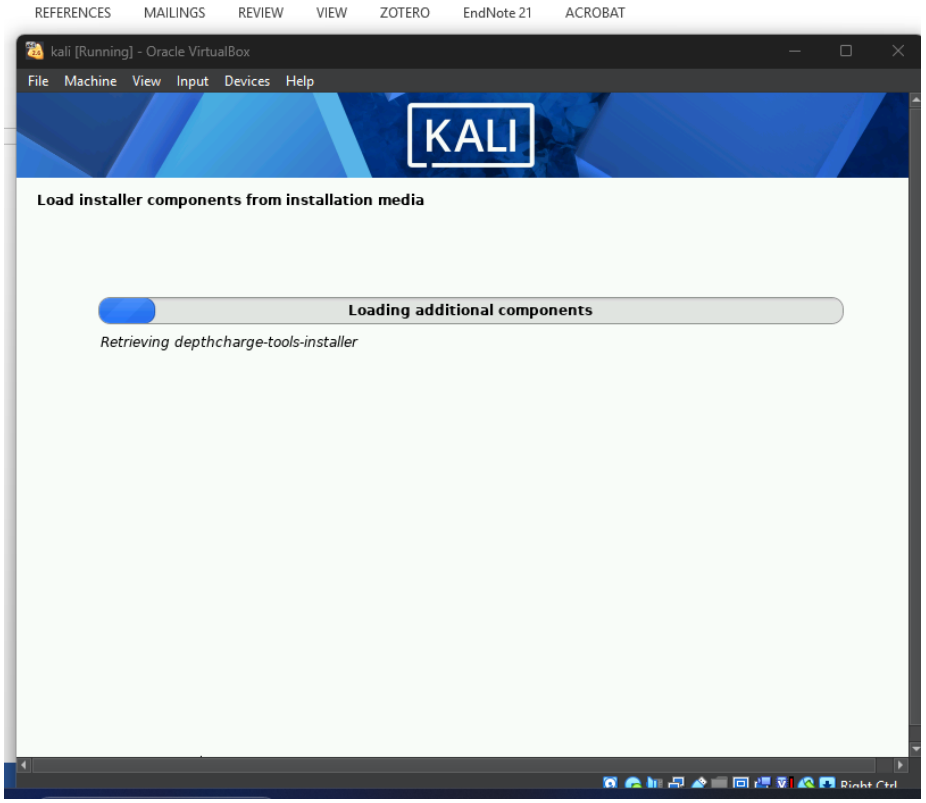


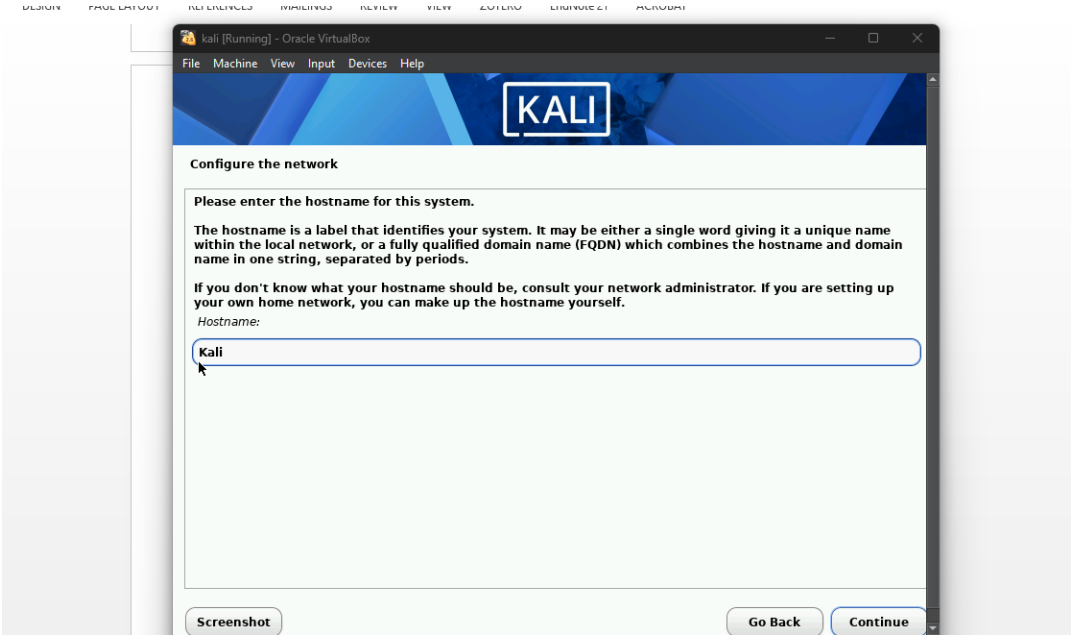


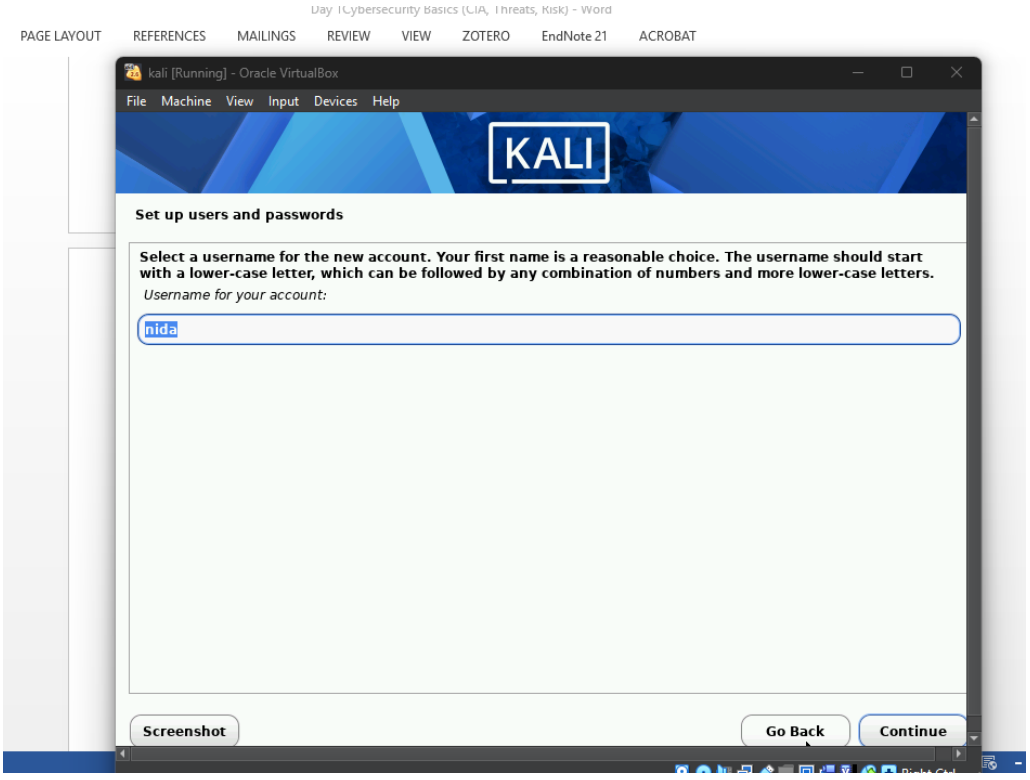

Machine View Input Devices Help
KALI
Select a language
Choose the language to be used for the installation process. The selected language will also be the default language for the installed system.
Language:
Chinese (Traditional) - 中文(繁體)
Croatian - Hrvatski
Czech - Čeština
Danish - Dansk
Dutch - Nederlands
Dzongkha -
English - English
Esperanto - Esperanto
Estonian - Eesti
Finnish - Suomi
French - Français
Galician - Galego
Georgian - ქართული
German - Deutsch
Screenshot
Go Back
Continue
Mouse integration
Auto capture keyb

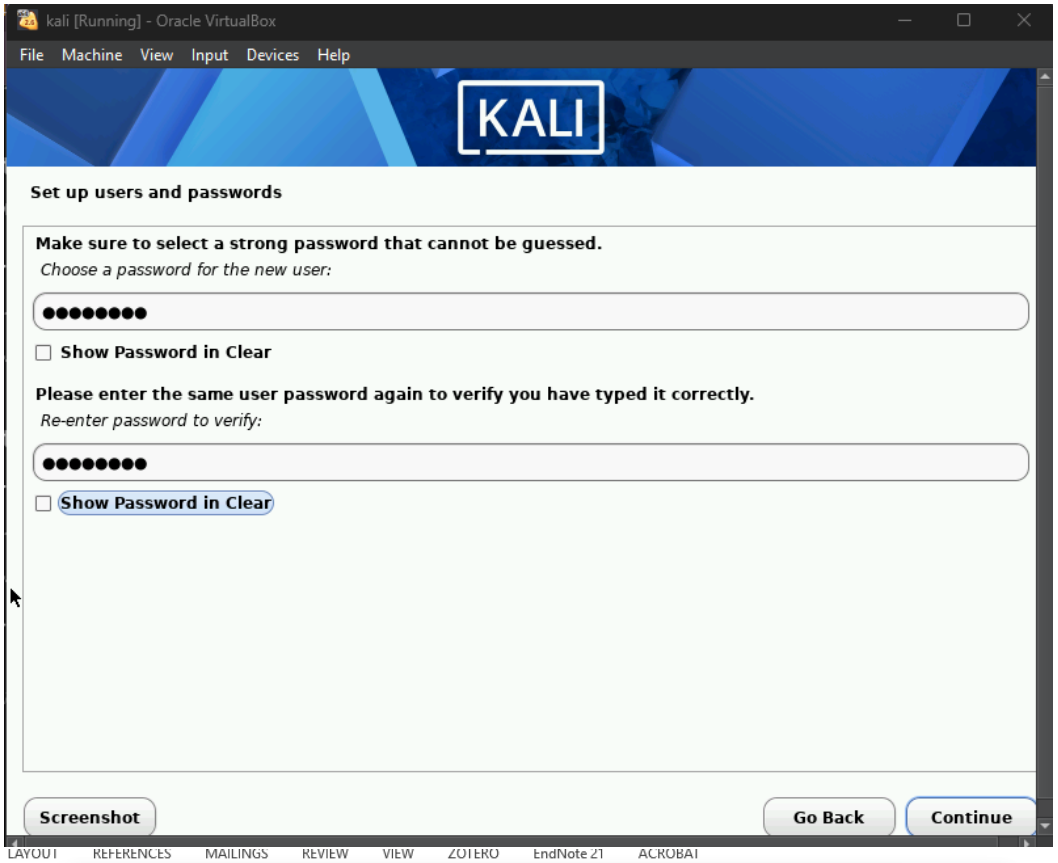

kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Select your location
The selected location will be used to set your time zone and also for example to help select the system locale. Normally this should be the country where you live.
This is a shortlist of locations based on the language you selected. Choose "other" if your location is not listed.
Country, territory or area:
India
Ireland
Israel
New Zealand
Nigeria
Philippines
Seychelles
Singapore
South Africa
United Kingdom
United States
Zambia
Zimbabwe
Screenshot
Go Back
Continue

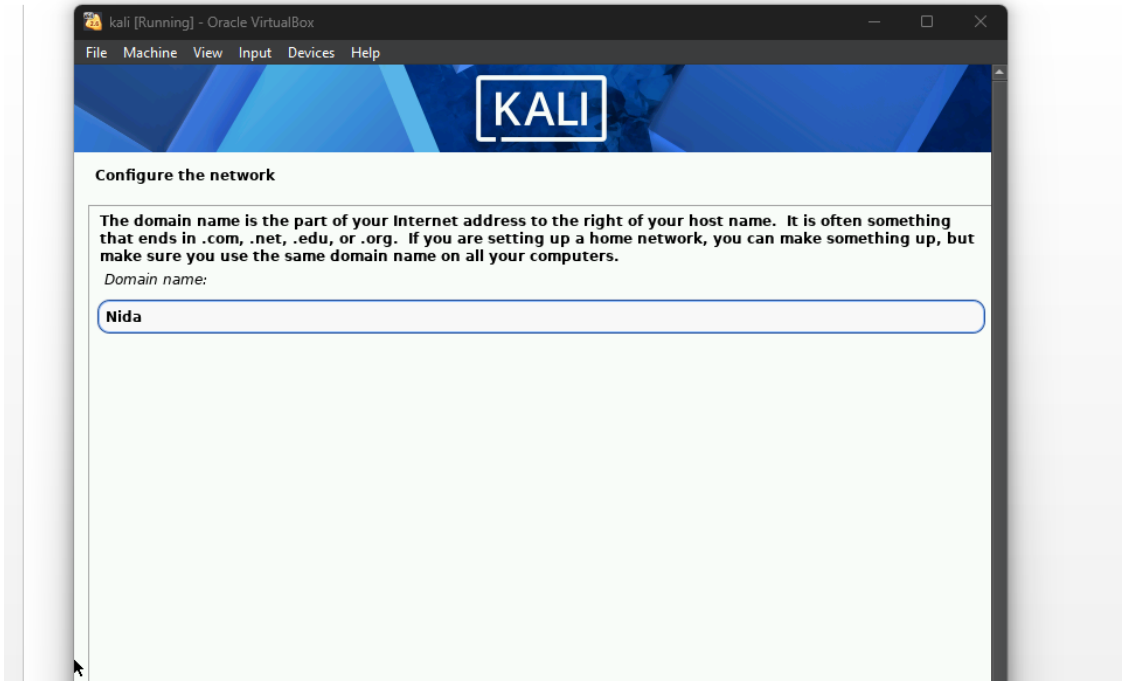

kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Configure the keyboard
Keymap to use:
American English
Albanian
Arabic
Asturian
Bangladesh
Belarusian
Bengali
Belgian
Berber (Latin)
Bosnian
Brazilian
British English
Bulgarian (BDS layout)
Bulgarian (phonetic layout)
Burmese
Canadian French
Screenshot
Go Back
Continue

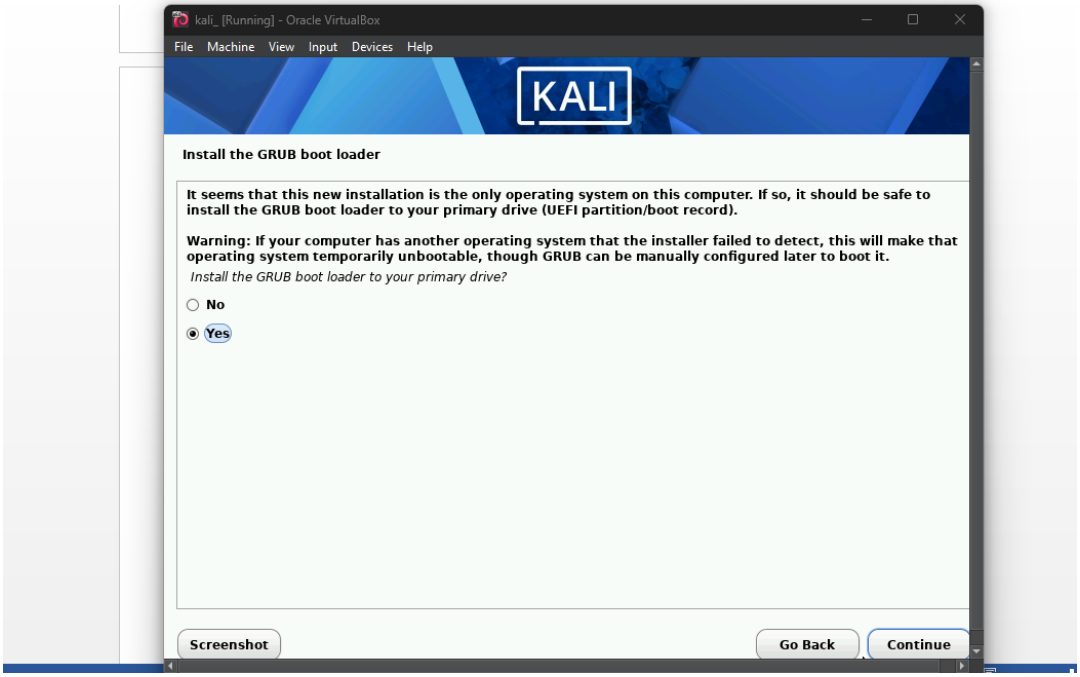

kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Load installer components from installation media
Loading additional components
Retrieving depthcharge-tools-installer

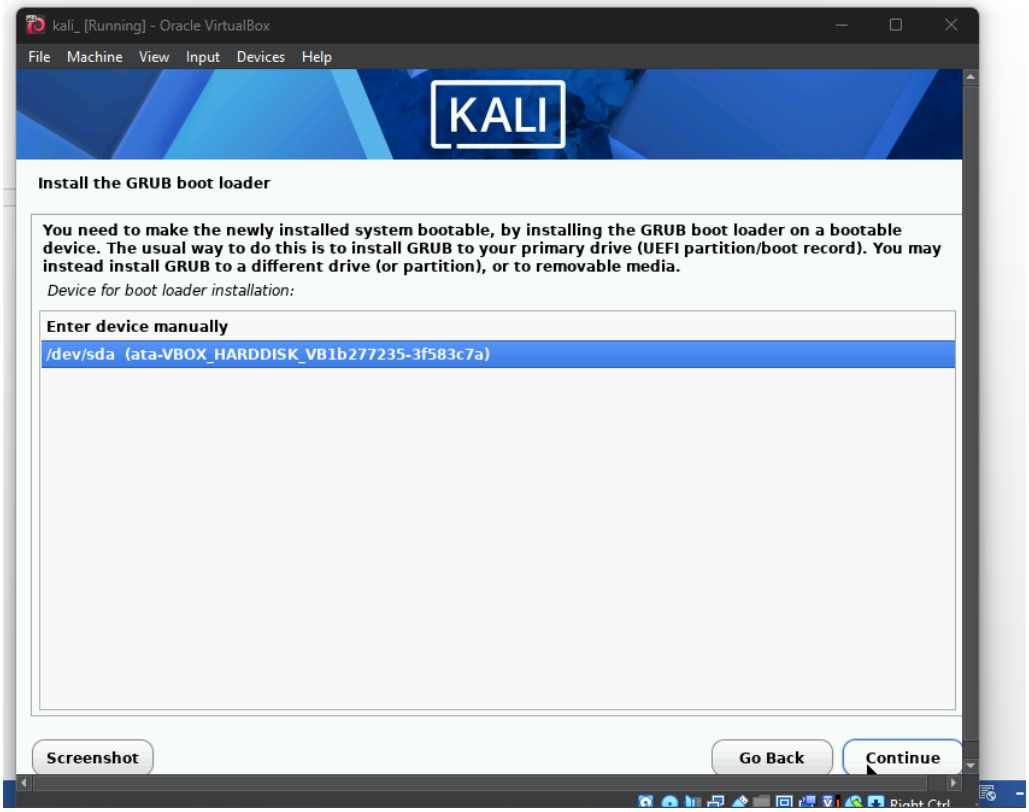

kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Configure the network
Please enter the hostname for this system.
The hostname is a label that identifies your system. It may be either a single word giving it a unique name within the local network, or a fully qualified domain name (FQDN) which combines the hostname and domain name in one string, separated by periods.
If you don't know what your hostname should be, consult your network administrator. If you are setting up your own home network, you can make up the hostname yourself.
Hostname:
Kali
Screenshot
Go Back
Continue

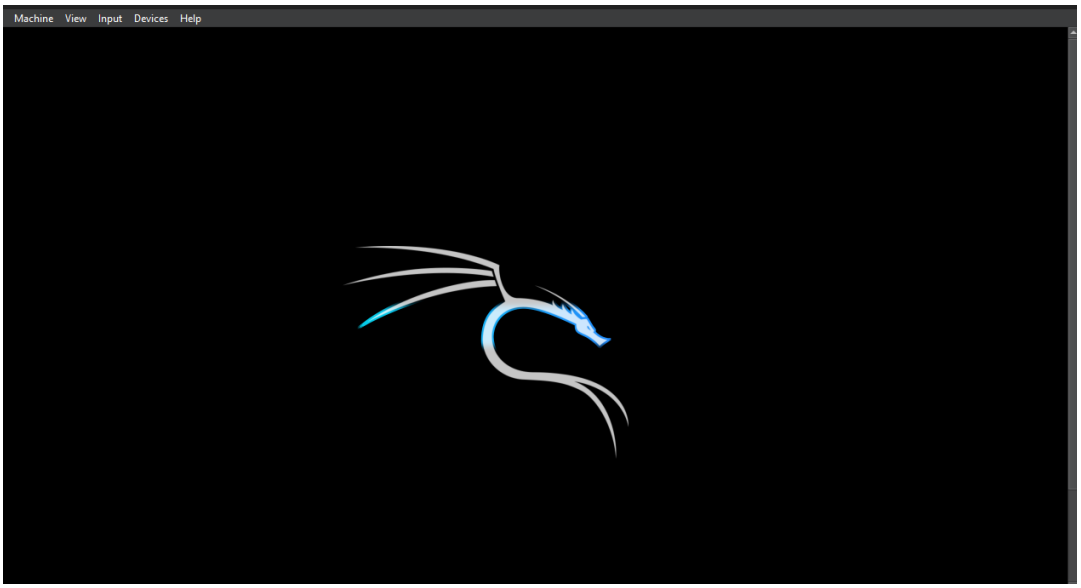

Day 1Cybersecurity Basics (CIA, Threats, Risk) - Word
PAGE LAYOUT REFERENCES MAILINGS REVIEW VIEW ZOTERO EndNote 21 ACROBAT
kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Set up users and passwords
Select a username for the new account. Your first name is a reasonable choice. The username should start with a lower-case letter, which can be followed by any combination of numbers and more lower-case letters.
Username for your account:
nida
Screenshot
Go Back
Continue


kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Set up users and passwords
Make sure to select a strong password that cannot be guessed.
Choose a password for the new user:
Show Password in Clear
Please enter the same user password again to verify you have typed it correctly.
Re-enter password to verify:
Show Password in Clear
Screenshot
Go Back
Continue


kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Configure the network
The domain name is the part of your Internet address to the right of your host name. It is often something that ends in .com, .net, .edu, or .org. If you are setting up a home network, you can make something up, but make sure you use the same domain name on all your computers.
Domain name:
Nida


kali_ [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Install the GRUB boot loader
It seems that this new installation is the only operating system on this computer. If so, it should be safe to install the GRUB boot loader to your primary drive (UEFI partition/boot record).
Warning: If your computer has another operating system that the installer failed to detect, this will make that operating system temporarily unbootable, though GRUB can be manually configured later to boot it.
Install the GRUB boot loader to your primary drive?
No
Yes
Screenshot
Go Back
Continue


kali_ [Running] - Oracle VirtualBox
File Machine View Input Devices Help
KALI
Install the GRUB boot loader
You need to make the newly installed system bootable, by installing the GRUB boot loader on a bootable device. The usual way to do this is to install GRUB to your primary drive (UEFI partition/boot record). You may instead install GRUB to a different drive (or partition), or to removable media.
Device for boot loader installation:
Enter device manually
/dev/sda (ata-VBOX_HARDDISK_VB1b277235-3f583c7a)
Screenshot
Go Back
Continue

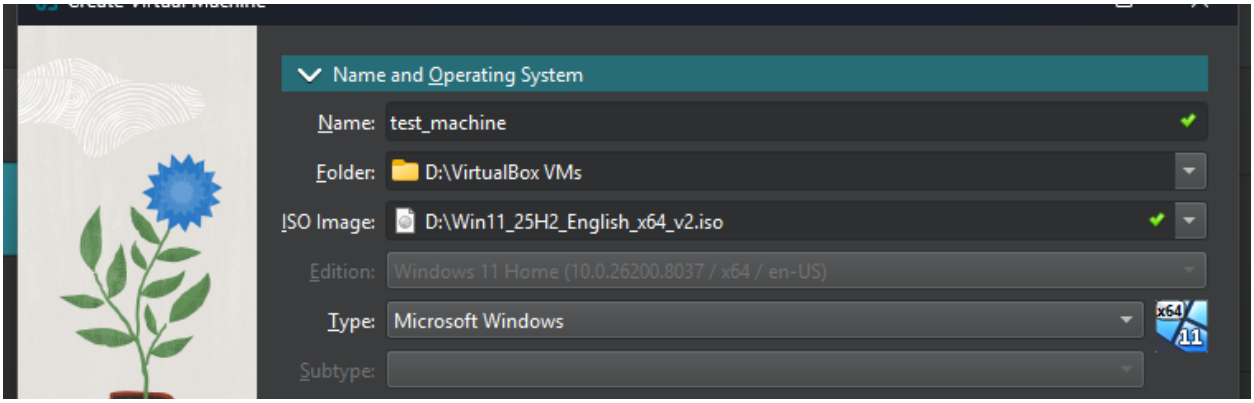

Machine View Input Devices Help

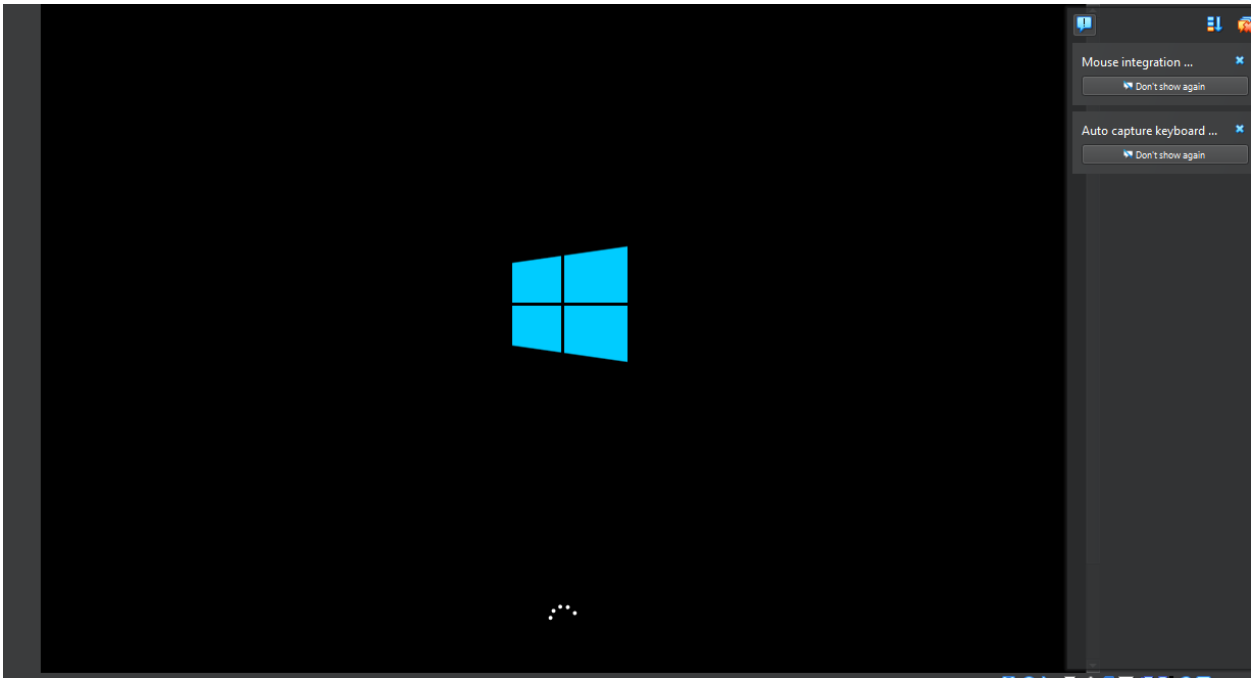


Day 5: Install Windows Test Machine

Tools: Windows ISO, VirtualBox / VMware

Practical Task: Install Windows test VM for lab testing.



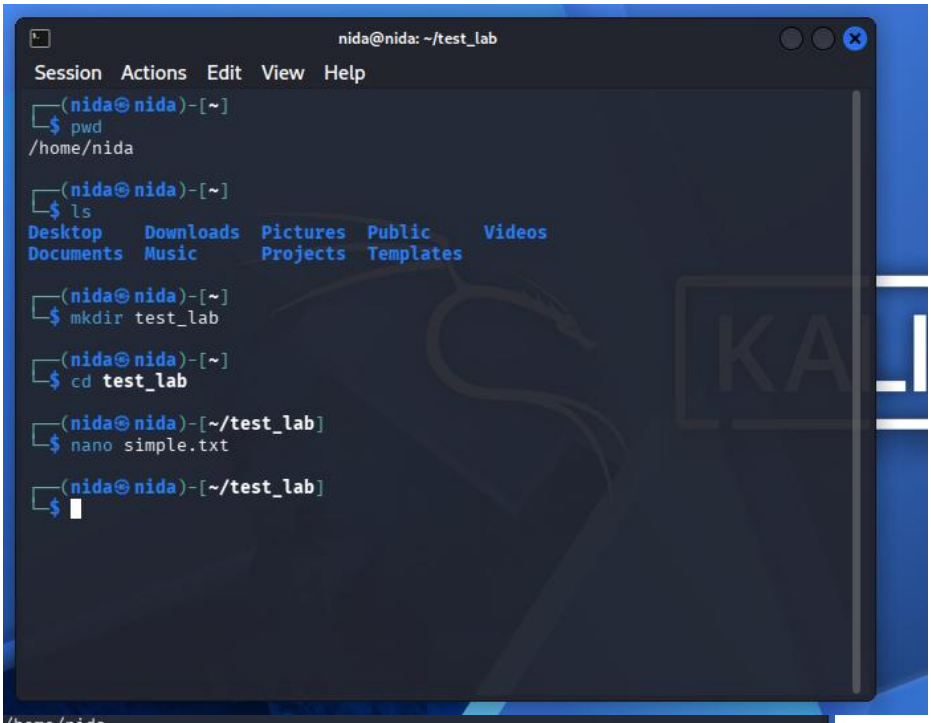

Mouse integration ...
Don't show again
Auto capture keyboard ...
Don't show again

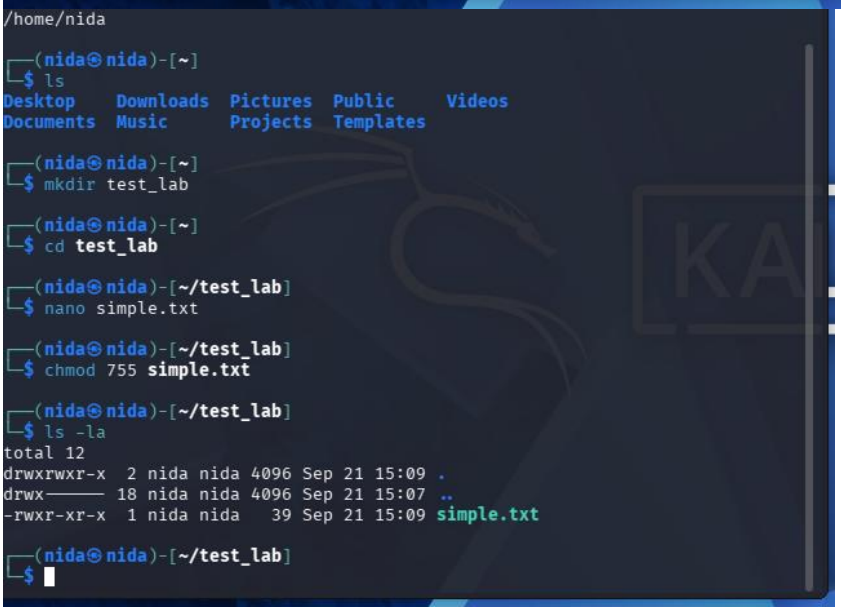

Press Ctrl+Alt+Delete to unlock.
12:03

Day 6: Linux Commands Practice

Tools: Kali Linux Terminal

Practical Task: Practice ls, pwd, cd, mkdir, nano, chmod commands.

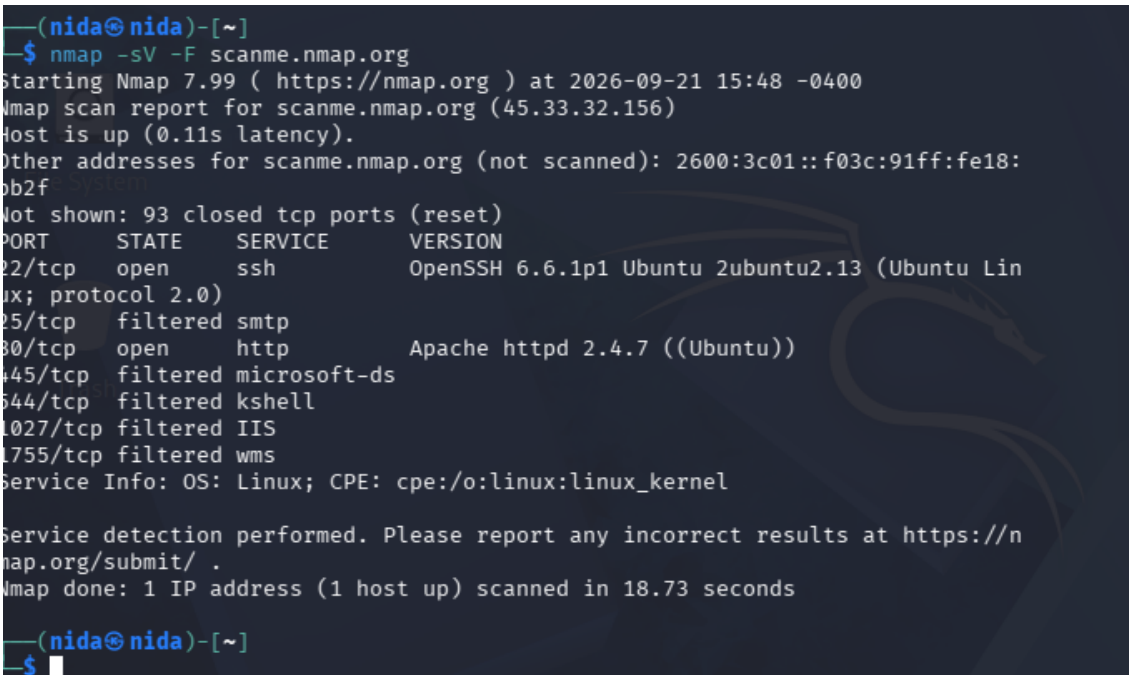




Day 7: Basic Network Scanning

Tools: Nmap

Practical Task: Scan local lab network and identify open ports.



WEEK 2 – Ethical Hacking & Vulnerability Assessment

Day 8: Ethical Hacking Methodology

. Penetration Testing Methodology & Phases

Penetration testing is a structured process used by security professionals to evaluate the security posture of networks, systems, and applications. It follows five distinct phases:

1. **Reconnaissance (Information Gathering):**

- **Passive Reconnaissance:** Gathering target intelligence without direct interaction (e.g., OSINT, WHOIS records, public search engines).

- **Active Reconnaissance:** Directly probing the target infrastructure for details (e.g., DNS queries, banner grabbing).

2. **Scanning & Enumeration:**

- Identifying active hosts, open TCP/UDP ports, and running service versions.
- Mapping network topology and detecting operating system signatures.

3. **Vulnerability Assessment:**

- Analyzing target services and configurations to identify known security flaws.
- Utilizing automated scanners and manual analysis to detect logic errors and missing patches.

4. **Exploitation & Post-Exploitation:**

- **Exploitation:** Safely leveraging identified vulnerabilities to gain unauthorized system access.
- **Post-Exploitation:** Performing privilege escalation, testing lateral movement, and maintaining persistence to determine potential impact.
- **Cleanup:** Reverting system changes, removing test files, and disabling temporary user accounts created during testing.

5. **Reporting & Remediation:**

   Compiling technical findings, severity scores, and actionable remediation steps into a formal document.

2. Standard Penetration Testing Report Format

A professional penetration testing report contains six primary sections:

Section 1: Title & Document Control

- **Document Name:** Penetration Testing & Vulnerability Assessment Report
- **Target / Scope:** Client Name / Specific IP Ranges / Domain URLs
- **Date & Version:** Document Version (e.g., v1.0) and Testing Window Dates
- **Author Details:** Security Tester / Analyst Name and Contact Information

Section 2: Executive Summary

- High-level overview tailored for non-technical leadership and management.
- Summary of overall security posture and key risk drivers.
- High-level vulnerability distribution (Critical, High, Medium, Low).

Section 3: Scope of Work & Rules of Engagement

- **In-Scope Assets:** Authorized domains, IP blocks, APIs, and web applications.
- **Out-of-Scope Assets:** Explicitly prohibited production systems and third-party services.
- **Testing Window:** Approved operational hours and testing timeframe.

Section 4: Methodology & Tools Applied

- Applied testing standards (e.g., PTES, OWASP Top 10, NIST SP 800-115).
- List of automated and manual security testing tools used.

Section 5: Detailed Technical Findings

Field	Description
Vulnerability Title	Concise name (e.g., SQL Injection in Authentication Module)
Severity Rating	Critical / High / Medium / Low (with CVSS Score)
Affected Endpoint	Specific URL, IP address, or port number
Description	Detailed technical explanation of the vulnerability
Proof of Concept (PoC)	Step-by-step reproduction steps, payloads, and terminal logs
Impact	Potential threat to Confidentiality, Integrity, or Availability

Section 6: Remediation & Recommendations

- **Short-Term Mitigations:** Quick patches, temporary firewall rules, or configuration changes.
- **Long-Term Strategic Fixes:** Architectural enhancements, secure coding training, and automated patch management.

Day 9: Reconnaissance

Tools: theHarvester, Whois

Practical Task: Perform information gathering on lab environment.

```
┌──(nida㉿nida)-[~]
└─$ whois scanme.nmap.org
Malformed request.
>>> Last update of WHOIS database: 2026-09-22T19:13:25Z <<<

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in t
he Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and Public Interest Re
gistry does not guarantee its accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful purposes and that,
 under no circumstances will you use this data to (a) allow, enable, or otherwise support the transmission by e-mail, telephone, or facsimile of mass unsolicited, com
mercial advertising or solicitations to entities other than the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes th
at send queries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to register domain names or modify existi
ng registrations. All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by
this policy.  The Registrar of Record identified in this output may have an RDDS service that can be queried for additional information on how to contact the Registra
nt, Admin, or Tech contact of the queried domain name.
```

```
┌──(nida㉿nida)-[~]
└─$ theHarvester -d nmap.org -b duckduckgo,crtsh -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                            _              *
* | |_| |__    ___      ^  /\__ _ _ ____   _____ ___| |_ ___ _ __  *
* | __|  _ \ / _ \    / /_/ / _` | '__\ \ / / _ v __| __/ _ \ '__| *
* | |_| | | |  __/ / __  / (_| | |   \ v /  __/\__ \ ||  __/ |    *
*  \__|_| |_|\___| v /_/ \__,_|_|    \_/ \___||___/\__\___|_|    *
*                                                                 *
* theHarvester 4.10.1                                             *
* Coded by Christian Martorella                                   *
* Edge-Security Research                                          *
* cmartorella@edge-security.com                                   *
*                                                                 *
*******************************************************************

[*] Target: nmap.org

[*] Searching CRTsh.
[*] Searching Duckduckgo.

[*] No IPs found.
```

```
[*] No emails found.

[*] No people found.

[*] Hosts found: 3
____________________
2Fsvn.nmap.org
scanme.nmap.org
svn.nmap.org
```

Day 10: Advanced Scanning

Tools: Nmap

Practical Task: Perform service version detection and OS detection.

```
┌──(nida㉿nida)-[~]
└─$ nmap -sV -O scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 15:29 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.00056s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 658 filtered tcp ports (no-response), 340 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.7 ((Ubuntu))
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (94%), Slirp (94%), AT&T embedded (91%), QEMU (89%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (94%), AT&T BGW210 voice gateway (91%), QEMU user mode network gateway (89%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 105.96 seconds
```

Day 11: Web Vulnerability Scanning

Tools: Nikto

Practical Task: Scan test web application in lab.

```
┌──(nida㉿nida)-[~]
└─$ nikto -h scanme.nmap.org
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          45.33.32.156
+ Target Hostname:    scanme.nmap.org
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-09-22 15:35:31 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.4.7 (Ubuntu)
+ Multiple IPs found: 45.33.32.156, 2600:3c01::f03c:91ff:fe18:bb2f
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
```

Day 13: Password Testing

Tools: Hydra / John the Ripper

Practical Task: Perform password strength testing in lab.

```
┌──(nida㉿nida)-[~]
└─$ sudo gunzip -f /usr/share/wordlists/rockyou.txt.gz 2>/dev/null || echo -e "12
3456\npassword\npassword123\nadmin" > pass.txt
[sudo] password for nida:

┌──(nida㉿nida)-[~]
└─$ echo "482c811da5d5b4bc6d497ffa98491e38" > hash.txt

┌──(nida㉿nida)-[~]
└─$ john --format=raw-md5 --wordlist=pass.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8×3])
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 4 candidates left, minimum 24 needed for performance.
password123      (?)
1g 0:00:00:00 DONE (2026-09-23 15:25) 50.00g/s 200.0p/s 200.0c/s 200.0C/s 123456.
.admin
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords
 reliably
Session completed.

┌──(nida㉿nida)-[~]
└─$ john --show --format=raw-md5 hash.txt
?:password123

1 password hash cracked, 0 left
```

Day 14: Vulnerability Report Writing

Tools: MS Word / PDF

Practical Task: Prepare vulnerability assessment report with risk classification.



CYBERSECURITY LAB ASSESSMENT

DAY 14 PRACTICAL TASK

Vulnerability Assessment & Risk Classification Report

Comprehensive Security Audit & Automated Testing Review

TARGET ENVIRONMENT	ASSESSMENT DATE
Lab Infrastructure & Web Apps	September 24, 2026
ASSESSED BY	TOOLS UTILIZED
Security Analyst (nidaqtkali)	Nmap, Nikto, SQLmap, Hydra, John

This document serves as the formal deliverable for Day 14 of the Practical Penetration Testing Roadmap. It synthesizes findings from network discovery, web application scanning, database injection analysis, and credential strength evaluation.

CONFIDENTIAL & RESTRICTED — FOR INTERNAL USE ONLY

Vulnerability Assessment Report — Page 1 of 2



1. Executive Summary

2 2 1 2

2. Risk Classification Matrix

3. Key Remediation Steps

WEEK 3: Web Security & Blue Team Basics

Day 15: OWASP Top 10 Overview

OWASP?

The **Open Worldwide Application Security Project (OWASP)** publishes this standard awareness document to inform developers and security professionals about the most prevalent security risks in web applications.

OWASP Top 10 Vulnerabilities Overview

A01:2021 – Broken Access Control

- **Concept:** Users can act outside of their intended permissions (e.g., viewing another user's account details by changing an ID in the URL).
- **Prevention:** Enforce strict server-side access control checks and disable directory listing.

A02:2021 – Cryptographic Failures

- **Concept:** Exposure of sensitive data in transit or at rest due to weak or missing encryption (e.g., plain HTTP, weak hashing algorithms like MD5).
- **Prevention:** Enforce TLS 1.3, use standard strong cryptographic algorithms (AES-256, bcrypt/Argon2 for passwords), and avoid storing plain-text data.

A03:2021 – Injection

- **Concept:** Untrusted data is sent to an interpreter as part of a command or query (e.g., SQL Injection, OS Command Injection).
- **Prevention:** Use Parameterized Queries (Prepared Statements) and validate/sanitize input strictly.

A04:2021 – Insecure Design

- **Concept:** Flaws resulting from missing or ineffective security controls at the design and architectural phase.
- **Prevention:** Perform threat modeling, integrate security patterns into the architecture, and enforce secure design reviews.

A05:2021 – Security Misconfiguration

- **Concept:** Unhardened application setups, default passwords, open ports, verbose error messages revealing stack traces, or unneeded services left enabled.
- **Prevention:** Use automated baseline hardening, disable unnecessary features, and restrict error detail display to end-users.

A06:2021 – Vulnerable and Outdated Components

- **Concept:** Operating systems, libraries, or frameworks with known unpatched vulnerabilities (e.g., Log4j CVE-2021-44228).
- **Prevention:** Maintain a Software Bill of Materials (SBOM) and routinely patch dependencies using tools like npm audit or Dependency-Check.

A07:2021 – Identification and Authentication Failures

- **Concept:** Weaknesses in verifying a user's identity, allowing credential stuffing, brute-force attacks, or session hijacking.
- **Prevention:** Multi-Factor Authentication (MFA), lockout policies for brute-force prevention, and secure session management.

A08:2021 – Software and Data Integrity Failures

- **Concept:** Code or infrastructure that does not protect against integrity violations (e.g., auto-updates without digital signatures or insecure deserialization).
- **Prevention:** Verify digital signatures on dependencies and updates.

A09:2021 – Security Logging and Monitoring Failures

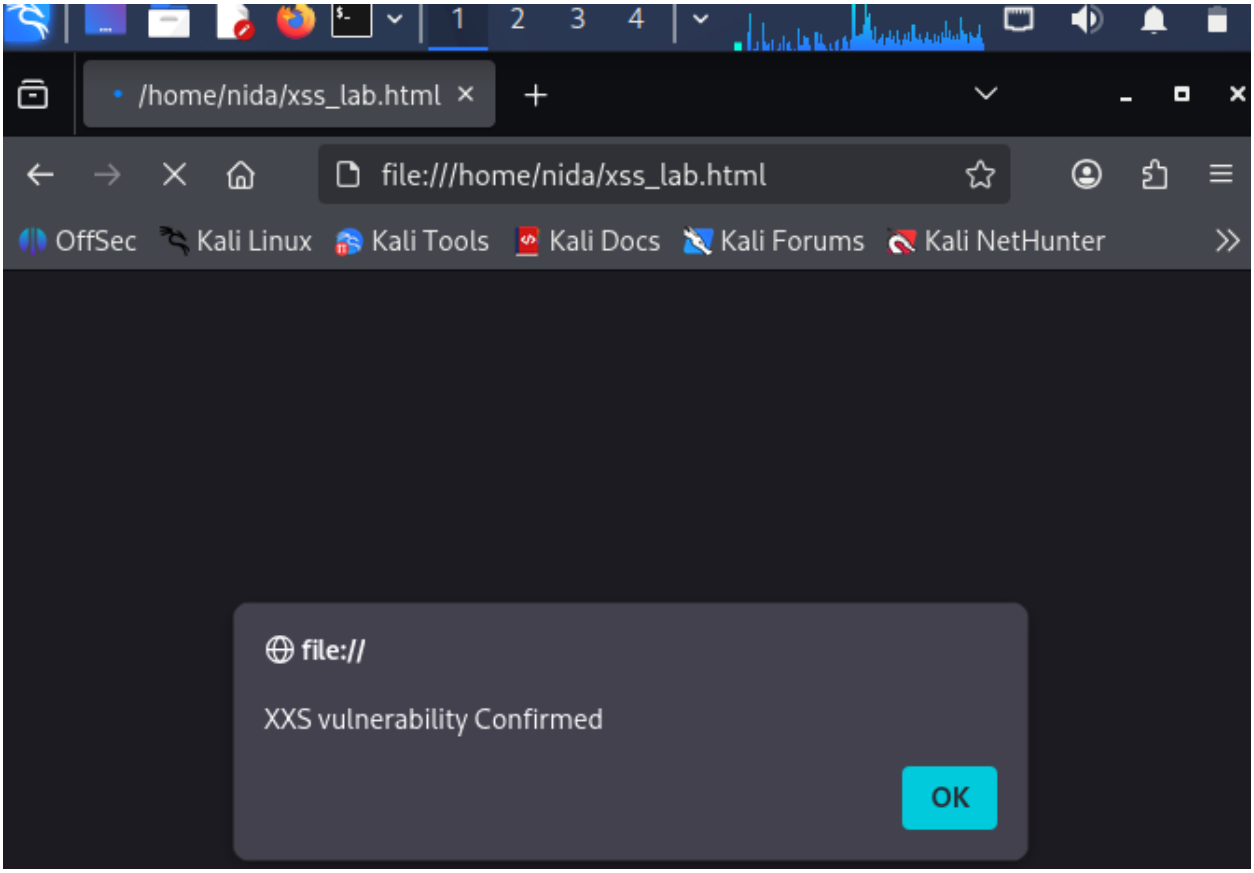
- **Concept:** Insufficient logging or real-time alerting, allowing attackers to remain undetected inside a network for extended periods.
- **Prevention:** Centralize logs (SIEM), implement active monitoring, and ensure audit logs cannot be modified.

A10:2021 – Server-Side Request Forgery (SSRF)

- **Concept:** The web application fetches a remote resource without validating the user-supplied URL, allowing an attacker to read internal metadata endpoints or scan internal network ports.
- **Prevention:** Enforce strict URL whitelisting and restrict outgoing network requests from the web server.

Day 16: XSS Testing

Tools: Burp Suite / OWASP ZAP



Day 17: SQLi

Practice Tools: Burp Suite, SQLmap

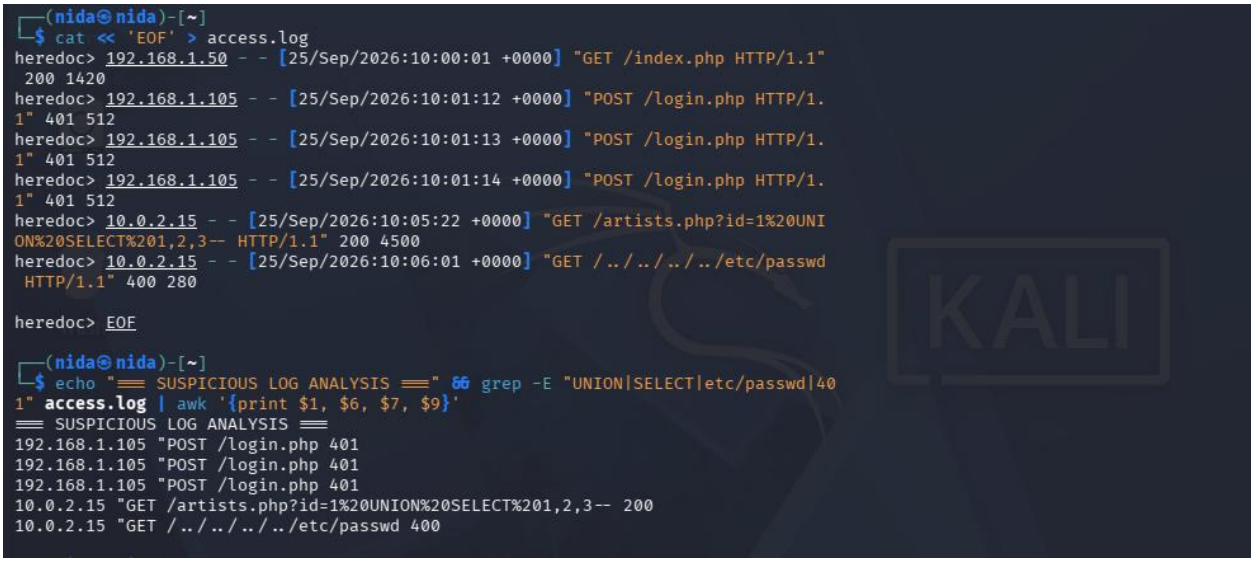
Practical Task: Perform manual & automated SQL testing.



Day 18: Log Analysis

Basics Tools: Sample Log Files

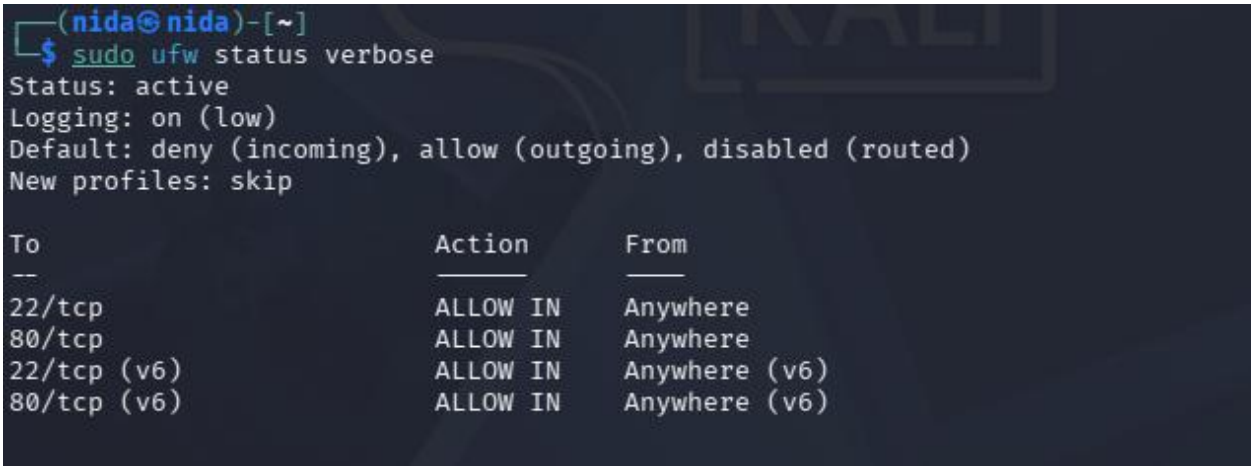
Practical Task: Analyze logs and detect suspicious activity.



Day 19: Firewall Configuration

Tools: Windows Firewall / UFW

Practical Task: Create basic inbound & outbound rules.



Day 21: Incident Simulation

Tools: Lab Environment

Practical Task: Simulate basic attack and document response steps.

```
┌──(nida㉿nida)-[~]
└─$ logger -t INCIDENT_ALERT "CRITICAL: Unauthorized SSH brute-force detected fro
m IP 192.168.1.250"

┌──(nida㉿nida)-[~]
└─$ sudo iptables -A INPUT -s 192.168.1.250 -j DROP
[sudo] password for nida:

┌──(nida㉿nida)-[~]
└─$ echo -e "\n=== INCIDENT RESPONSE SUMMARY REPORT ===" && \
cmdand> echo "Timestamp  : $(date '+%Y-%m-%d %H:%M:%S')" && \
cmdand cmdand> echo "Incident ID  : SSH Brute Force Attack" && \
cmdand cmdand cmdand> echo "Attacker IP  : 192.168.1.250" && \
cmdand cmdand cmdand cmdand> echo "Status : CONTAINED & BLOCKED" && \
cmdand cmdand cmdand cmdand cmdand> echo -e "--------------------------------\n[L
OG EVIDENCE]" && \
cmdand cmdand cmdand cmdand cmdand cmdand> sudo journalctl -k -n 1 --grep="INCIDE
NT ALERT" 2>/dev/null || grep "INCIDENT_ALERT" /var/log/syslog | tail -n 1

=== INCIDENT RESPONSE SUMMARY REPORT ===
Timestamp  : 2026-09-26 16:08:08
Incident ID  : SSH Brute Force Attack
Attacker IP  : 192.168.1.250
Status : CONTAINED & BLOCKED
--------------------------------
[LOG EVIDENCE]
-- No entries --
grep: /var/log/syslog: No such file or directory
```

WEEK 4 – Hardening & Final Project

Day 22: System Hardening Basics

Tools: Windows Services

Practical Task: Disable unnecessary services.

```
┌──(nida㉿nida)-[~]
└─$ sudo systemctl status bluetooth
[sudo] password for nida:
○ bluetooth.service - Bluetooth service
     Loaded: loaded (/usr/lib/systemd/system/bluetooth.service; disabled; prese>
     Active: inactive (dead)
       Docs: man:bluetoothd(8)

┌──(nida㉿nida)-[~]
└─$ sudo systemctl is-enabled bluetooth && sudo systemctl is-active bluetooth
disabled
```

Day 23: Firewall Hardening

Tools: Windows Firewall / UFW

Practical Task: Apply advanced firewall rules.

```
┌──(nida㉿nida)-[~]
└─$ sudo ufw deny from 192.168.1.0/24 to any port 22
Rule added

┌──(nida㉿nida)-[~]
└─$ sudo ufw limit 22/tcp
Rule updated
Rule updated (v6)

┌──(nida㉿nida)-[~]
└─$ sudo ufw status numbered
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] 22/tcp                     LIMIT IN    Anywhere
[ 2] 80/tcp                     ALLOW IN    Anywhere
[ 3] 22                         DENY IN     192.168.1.0/24
[ 4] 22/tcp (v6)                LIMIT IN    Anywhere (v6)
[ 5] 80/tcp (v6)                ALLOW IN    Anywhere (v6)
```

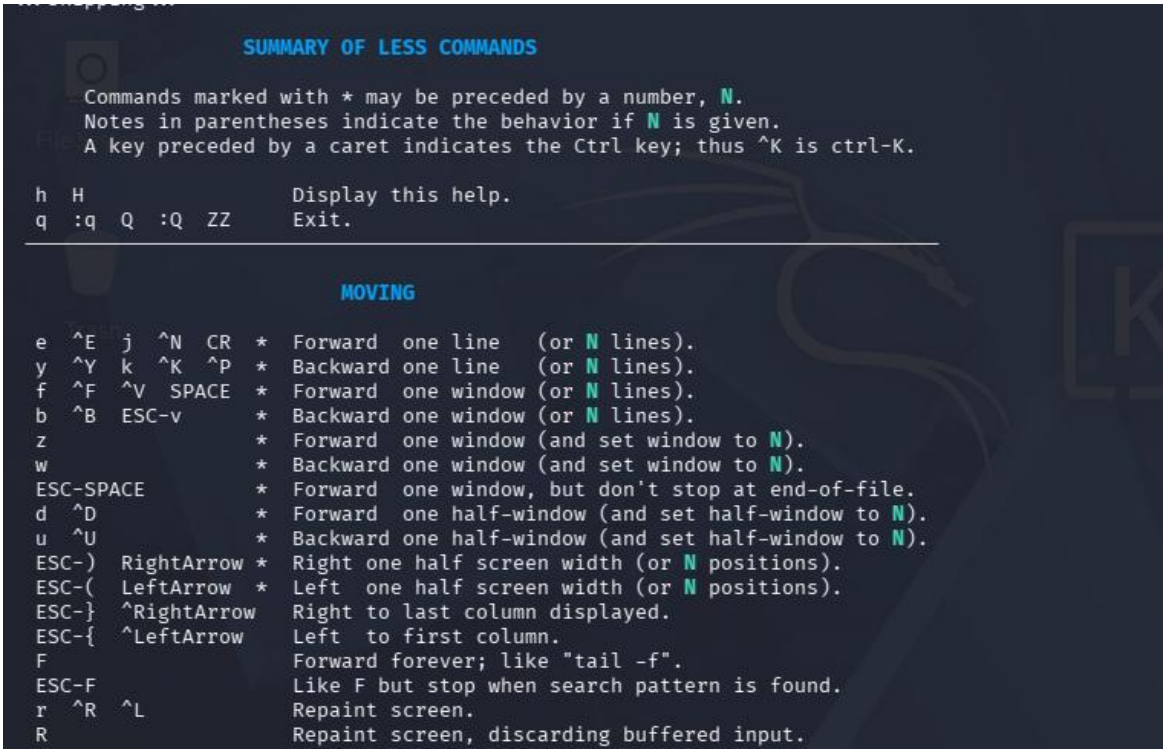
Day 24: Password Policy Implementation

Tools: Local Security Policy

Practical Task: Apply strong password policy.

```
┌──(nida㉿nida)-[~]
└─$ sudo apt update
[sudo] password for nida:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.6 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [54.2 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [183 kB
]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [170 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [893 k
B]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [16
.0 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (de
b) [42.3 kB]
Fetched 77.3 MB in 33s (2,365 kB/s)
1456 packages can be upgraded. Run 'apt list --upgradable' to see them.

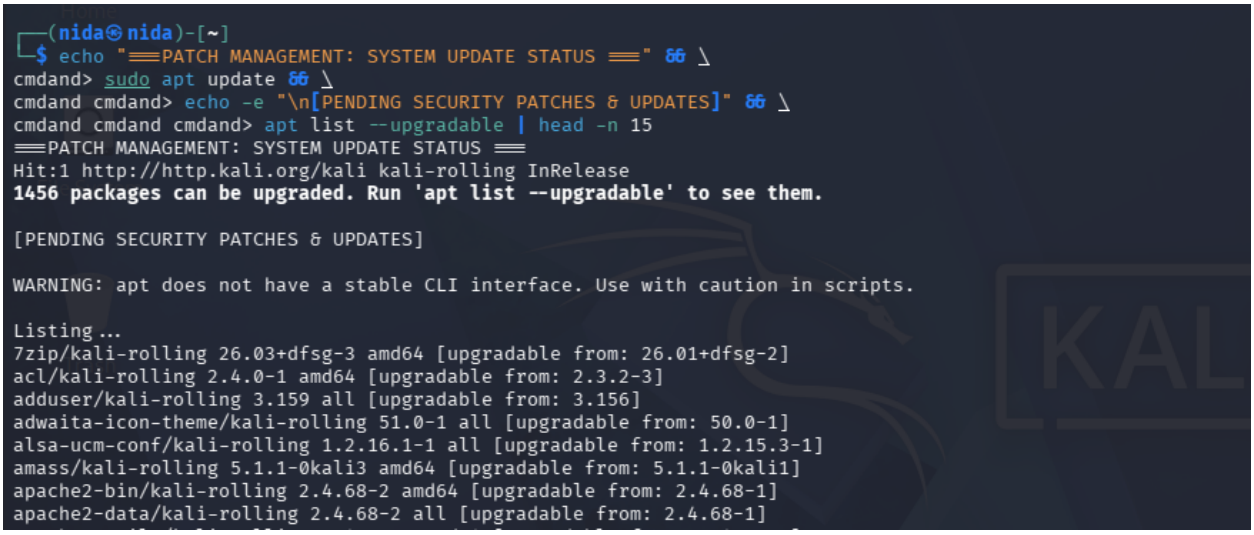
┌──(nida㉿nida)-[~]
└─$ apt list --upgradable
7zip/kali-rolling 26.03+dfsg-3 amd64 [upgradable from: 26.01+dfsg-2]
acl/kali-rolling 2.4.0-1 amd64 [upgradable from: 2.3.2-3]
adduser/kali-rolling 3.159 all [upgradable from: 3.156]
adwaita-icon-theme/kali-rolling 51.0-1 all [upgradable from: 50.0-1]
alsa-ucm-conf/kali-rolling 1.2.16.1-1 all [upgradable from: 1.2.15.3-1]
amass/kali-rolling 5.1.1-0kali3 amd64 [upgradable from: 5.1.1-0kali1]
apache2-bin/kali-rolling 2.4.68-2 amd64 [upgradable from: 2.4.68-1]
apache2-data/kali-rolling 2.4.68-2 all [upgradable from: 2.4.68-1]
apache2-utils/kali-rolling 2.4.68-2 amd64 [upgradable from: 2.4.68-1]
apache2/kali-rolling 2.4.68-2 amd64 [upgradable from: 2.4.68-1]
apparmor/kali-rolling 4.1.8-2 amd64 [upgradable from: 4.1.7-4]
apt-file/kali-rolling 3.4 all [upgradable from: 3.3]
apt-utils/kali-rolling 3.3.3+kali1 amd64 [upgradable from: 3.2.0+kali1]
```



Day 25: Patch Management

Tools: Windows Update

Practical Task: Check updates and apply patches.



Day 26: Security Baseline Implementation

Tools: Windows Security Settings

Practical Task: Apply recommended security settings.

```
directs net.ipv4.conf.all.rp_filter
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.rp_filter = 0
```

Day 27: Full Lab Security Review

Tools: Nmap

Practical Task: Re-scan hardened system using Nmap.

```
┌──(nida㉿nida)-[~]
└─$ echo "══ POST-HARDENING SYSTEM SECURITY RESCAN  ══" && \
cmdand> echo "\n[NMAP LOCALHOST AUDIT]" && \
cmdand cmdand> sudo nmap -sS -sV -p 22,80,443,445 127.0.0.1
══ POST-HARDENING SYSTEM SECURITY RESCAN  ══

[NMAP LOCALHOST AUDIT]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 15:19 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000047s latency).

PORT    STATE  SERVICE      VERSION
22/tcp  closed ssh
80/tcp  closed http
443/tcp closed https
445/tcp closed microsoft-ds

Service detection performed. Please report any incorrect results at https://nmap.
org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.39 seconds
```

THE END